

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

REGISTRO DELLE VALUTAZIONI D'IMPATTO (DPIA)

Area 09 – Privacy

Codice	Revisione	Data	Pagine
TD-SGI-MOD212_00	00	30/04/2026	4
Redatto da	Approvato da	Classificazione	Stato
DPO + RSGI	AD – Francesco Epifani	Riservato Alta Direzione + DPO	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
30/04/2026	30/04/2026	30/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo

Il presente registro raccoglie e traccia le valutazioni d'impatto sulla protezione dei dati (DPIA — Data Protection Impact Assessment) condotte da Toscana Diagnostica S.r.l. ai sensi dell'art. 35 del Regolamento (UE) 2016/679 (GDPR), in coerenza con le Linee Guida WP248 e con le indicazioni del Garante Privacy (Provvedimento n. 467/2018 — Lista delle tipologie di trattamento da sottoporre a DPIA).

Il registro è mantenuto dal DPO con il supporto del RSGI e dell'IT Manager. Ogni DPIA è collegata al Registro dei Trattamenti TD-SGI-REG004 e — quando applicabile — al Registro Sistemi AI MOD197.

2. Riferimenti

Riferimento	Ambito
Reg. (UE) 2016/679 art. 35 (GDPR)	Obbligo DPIA
WP248 rev. 01 (Article 29 WP) — Linee Guida DPIA	Metodologia europea
Provvedimento Garante n. 467/2018	Tipologie obbligatorie di DPIA
EDPB Guidelines 1/2025	Aggiornamenti DPO + DPIA
AI Act Reg. UE 2024/1689 art. 27	DPIA per sistemi AI ad alto rischio
TD-SGI-REG004	Registro Trattamenti ex art. 30 GDPR
TD-SGI-MOD197	Registro Sistemi AI
TD-SGI-PRO030-037	Procedure Privacy

3. Trigger di obbligatorietà DPIA

Una DPIA è **OBBLIGATORIA** quando il trattamento ricade in uno dei seguenti casi (art. 35 c. 3 GDPR + Provvedimento 467/2018):

- (a) valutazione sistematica e globale di aspetti personali, basata su trattamenti automatizzati (incluso profiling) che producono effetti giuridici o significativi sulla persona;
- (b) trattamento su larga scala di categorie particolari (Cat. 9 GDPR — dati sanitari, genetici, biometrici);
- (c) sorveglianza sistematica di aree accessibili al pubblico su larga scala;
- (d) trattamenti che combinano due o più criteri della Lista WP248 (es. dati sensibili + sorveglianza + uso di nuove tecnologie come AI);
- (e) trattamenti su soggetti vulnerabili (minori, pazienti, lavoratori) su larga scala;
- (f) sistemi AI classificati ad alto rischio ai sensi dell'AI Act art. 6-7.

4. Tabella di registro DPIA

#	Voce	Esempio compilazione
1	ID DPIA (formato DPIA-yyyy-###)	DPIA-2026-001
2	Titolo del trattamento	Refertazione automatica con supporto AI per imaging radiologico

3	Data avvio DPIA	gg/mm/aaaa
4	Data completamento	gg/mm/aaaa
5	Funzione richiedente / Titolare interno	Direttore Sanitario / IT Manager
6	Trattamento collegato (rif. REG004)	Trattamento n. ____ del Registro art. 30
7	Sistema AI collegato (rif. MOD197)	AI-YYYY-### (se applicabile)
8	Trigger di obbligatorietà (rif. §3)	Punto (b) e/o (f)
9	Categorie di interessati	Pazienti — adulti / minori
10	Categorie di dati personali	Dati anagrafici + dati sanitari (Cat. 9) + dati di imaging
11	Finalità del trattamento	Diagnosi clinica + supporto decisionale al medico
12	Base giuridica	Art. 9 c. 2 lett. h) GDPR (finalità di medicina e diagnosi)
13	Volumi e durata	Stima n. interessati/anno; periodo di conservazione
14	Mappatura del flusso dati	Origine → Trasferimenti → Conservazione → Cancellazione
15	Identificazione dei rischi (per i diritti degli interessati)	[lista — es. accesso non autorizzato, errore diagnostico, profilazione indebita]
16	Probabilità (1-5) e gravità (1-5) per ciascun rischio	Matrice di rischio
17	Misure tecniche e organizzative di mitigazione	Cifratura, accesso RBAC, HITL, audit log, formazione
18	Rischio residuo	Accettabile / Da rivalutare / Inaccettabile
19	Esito DPIA	Approvata / Approvata con condizioni / Rivista / Sottoposta a consultazione preventiva al Garante (art. 36)
20	Parere del DPO	Allegato — riferimento documento
21	Eventuale consultazione del Garante (art. 36)	Sì/No, riferimento provvedimento
22	Data prossimo riesame DPIA	Annuale o on-event
23	Stato (In corso / Approvata / Da rivedere)	Approvata
24	Riferimento al fascicolo evidenze	Path archivio digitale

5. Sezione di registro corrente — anno 2026

Tabella sintetica di tutte le DPIA condotte nell'anno corrente. La presente è la baseline al lancio del registro: nessuna DPIA strutturata in formato MOD212 prima del 30/04/2026 (DPIA pregresse sono mantenute negli archivi del DPO).

ID	Titolo trattamento	Data avvio	Stato	Esito	Data riesame
DPIA-2026-001	[da popolare al primo trattamento]	—	—	—	—

6. DPIA programmate prioritariamente nel 2026

Il DPO, in coordinamento con il RSIG, identifica le seguenti DPIA prioritarie da condurre o aggiornare nel 2026:

#	Trattamento candidato a DPIA	Trigger	Owner	Data target
---	------------------------------	---------	-------	-------------

1	Sistemi AI di refertazione (radiologia, anatomia patologica) — ricognizione e classificazione	Cat. 9 + AI Act high-risk + nuove tecnologie	Direttore Sanitario + IT Manager + DPO	30/06/2026
2	Portale paziente per refertazione online	Cat. 9 + larga scala + accesso esterno	IT Manager + DPO	30/09/2026
3	Trattamenti per partecipazione a ricerca clinica / data altruism EHDS	Cat. 9 + ricerca + uso secondario dati	Direttore Sanitario + DPO	31/12/2026
4	Videosorveglianza aree accessibili al pubblico — riesame periodico	Sorveglianza sistematica	RSPP + DPO	30/06/2026
5	HR — sistemi automatizzati di valutazione/MBO con possibili effetti su rapporto di lavoro	Profiling dipendenti	P&C + DPO	30/09/2026

7. Riesame del registro

Il registro è oggetto di riesame trimestrale dal DPO con popolamento delle DPIA chiuse e annuale dal CdA su input del DPO + RSGI. Le DPIA aperte sono monitorate continuamente.

8. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	30/04/2026	Prima emissione del Registro DPIA di Toscana Diagnostica ai sensi dell'art. 35 GDPR e in coerenza con WP248 e Provvedimento Garante 467/2018. Tabella di registro a 24 voci per ogni DPIA. Cinque DPIA prioritarie programmate per il 2026 (sistemi AI, portale paziente, ricerca clinica/EHDS, videosorveglianza, HR profiling). Aggiornamento trimestrale dal DPO.	DPO + RSGI	AD